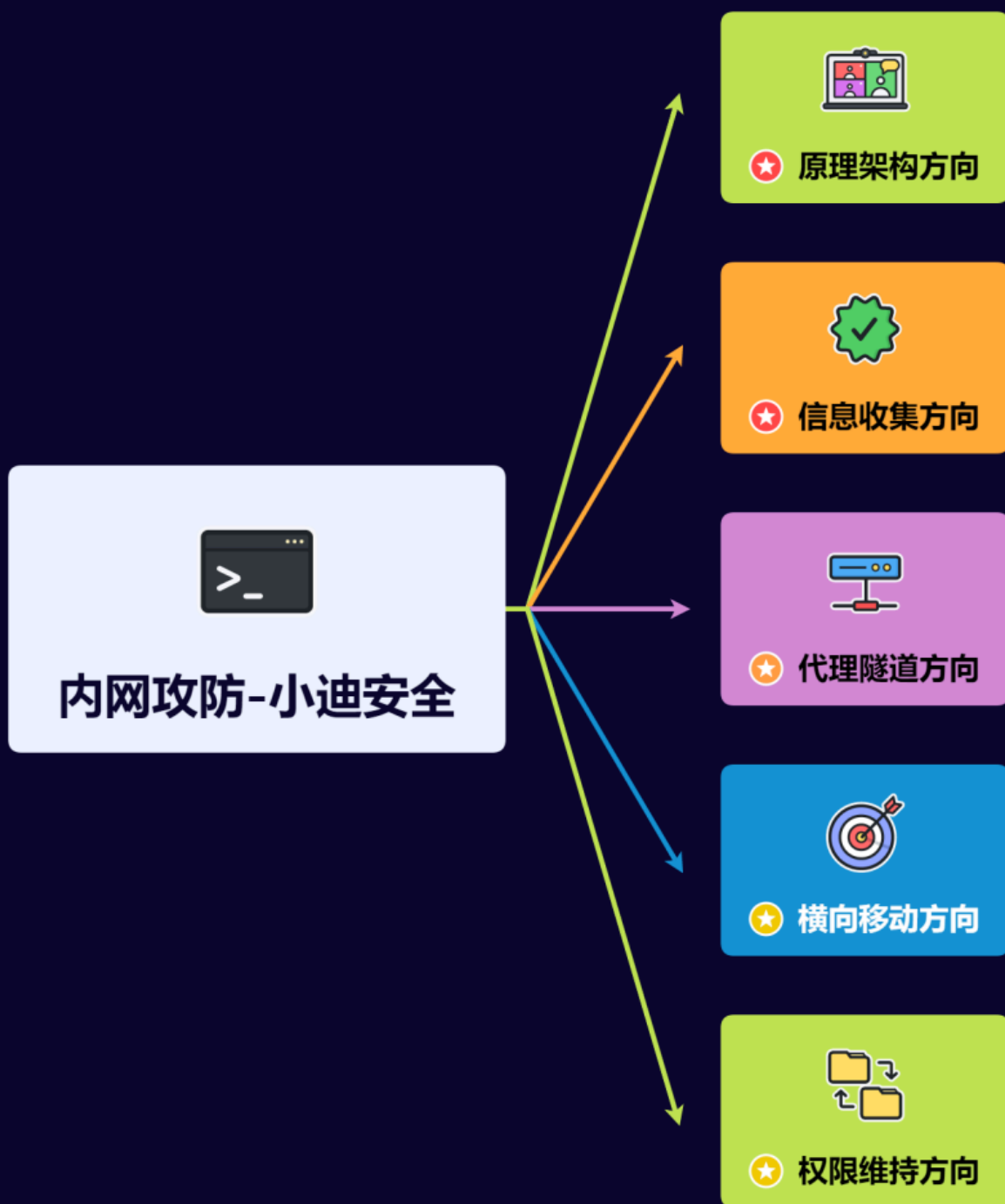


Day172 内网对抗-网络通讯篇&防火墙组策略&入站和出站规则&单层双层&C2正反向上线&解决方案



1.知识点

- 1、基石框架篇-单域架构-权限控制-用户和网络
- 2、基石框架篇-单域架构-环境搭建-准备和加入
- 3、基石框架篇-单域架构-信息收集-手工和工具

-
- 1、基石框架篇-父域子域架构-权限控制-用户和网络
 - 2、基石框架篇-父域子域架构-环境搭建-准备和加入
 - 3、基石框架篇-父域子域架构-信息收集-手工和工具

-
- 1、基石框架篇-域树&域林架构-权限控制-用户和网络
 - 2、基石框架篇-域树&域林架构-环境搭建-准备和加入
 - 3、基石框架篇-域树&域林架构-信息收集-手工和工具

-
- 1、代理隧道篇-代理通讯网络不可达-正反向连接上线
 - 2、代理隧道篇-代理通讯网络不可达-SockS代理配置

-
- 1、代理隧道篇-单向防火墙&双向防火墙-命令关闭
 - 2、代理隧道篇-单向防火墙&双向防火墙-正向反向
 - 3、代理隧道篇-单向防火墙&双向防火墙-隧道技术

2.详细点



- 1 1、认知处于什么网络环境下
- 2 2、认知内网域分类及成员架构
- 3 3、认知信息收集有那些重要信息
- 4 4、认知代理隧道有那些方法技术
- 5 5、认知横向移动有那些方法技术
- 6 5、认知权限维持有那些方法技术

2.1 工作组



- 1 将不同的计算机按照功能分别列入不同的工作组。想要访问某个部门的资源，只要在“网络”里面双击该部门的工作组名。工作组就像一个可以自由进入和退出的社团，方便同组的计算机相互访问，工作组没有集中管理作用，工作组里的计算机都是相互对等的（即没有服务器和客户机之分）。对局域网中的计算机进行分类，使得网络更有序。计算机的管理依然是各自为政，所有计算机依然是对等的，松散会员制，可以随意加入和退出，且不同工作组之间的共享资源可以相互访问。

2.2 内网域



- 1 分类：单域、子域、父域、域树、域森林、**DNS**域名服务器
- 2 “域”是一个有安全边界的计算机组合（一个域中的用户无法访问另一个域中的资源），域内资源由一台域控制器（**Domain Controller, DC**）集中管理，用户名和密码是放在域控制器去验证的。
- 3 优点：通过组策略来统一管理。
- 4 单域：即只有一个域的网络环境，一般需要两台**DC**，一台**DC**，另一台备用**DC**（容灾）
- 5 父子域：类比公司总部和公司分部的关系，总部的域称为父域，各分部的域称为该域的子域。使用父子域的好处：
 - 6 • 减小了域之间信息交互的压力（域内信息交互不会压缩，域间信息交互可压缩）
 - 7 • 不同的子域可以指定特定的安全策略
- 8 父子域中域名使用一个.表示一个层次，类似于**DNS**域名表示方式，子域只能使用父域的名字作为域名后缀
- 9 域树：多个域通过建立信任关系组成的集合。若两个域之间需要相互访问，需要建立信任关系（**Trust Relation**），通过信任关系可以将父子域连接成树状结构
- 10 域森林：多个域树通过建立信任关系组成的集合。
- 11 域名服务器：实现域名到**IP**地址的转换。由于域中计算机使用**DNS**来定位**DC**、服务器和其他计算机的，所以域的名字就是**DNS**域的名字。
- 12 内网渗透中，大都是通过寻找**DNS**服务器来确定域控制器位置（因为**DNS**服务器和域控制器通常配置在一台机器上）

2.3 域内权限



- 1 • 域本地组：
 - 2 • 多域用户访问单域资源
 - 3 • （访问同一个域），主要用于授予本域内资源的访问权限，可以从任何域中添加用户账号、通用组和全局组。域本地组无法嵌套在其他组中
- 4 • 全局组：
 - 5 • 单域用户访问多域资源
 - 6 • （必须是同一个域中的用户），只能在创建该全局组的域中添加用户和全局组，但可以在域森林中的任何域内指派权限，也可以嵌套在其他组中
- 7 • 通用组：多域用户访问多域资源，成员信息不保存在域控制器中，而是保存在全局编录（**GC**）中，任何变化都会导致全林复制

2.4 域内组划分



- 1 域本地组：来自全林作用于本域
- 2 全局组：来自本域作用于全林
- 3 通用组：来自全林作用于全林
- 4 本地域组的权限
- 5 **Administrators**（管理员组） ----最重要的权限
- 6 **Remote Desktop Users**（远程登录组）
- 7 **Print Operators**（打印机操作员组）
- 8 **Account Operators**（帐号操作员组）
- 9 **Server Operators**（服务器操作员组）
- 10 **Backup Operators**（备份操作员组）
- 11 全局组、通用组的权限
- 12 **Domain Admins**（域管理员组） ----最最最重要的权限，一般来说域渗透是看重这个

- 13 Enterprise Admins（企业系统管理员组）----最重要的权限，其次是去看重这个权限
- 14 Schema Admins（架构管理员组）----最重要的权限
- 15 Domain Users（域用户组）

2.5 A-G-DL-P策略

- 
- 1 A 代表用户账号（Account）。
 - 2 G 代表全局组（Global Group）。
 - 3 DL 代表域本地组（Domain Local Group）。
 - 4 P 代表资源访问权限（Permission）。
 - 5 A-G-DL-P策略是一种将用户账号添加到全局组中，然后将全局组添加到域本地组中，并为域本地组分配资源访问权限的策略。这种策略使得来自不同域的用户能够通过全局组和域本地组的组织方式，访问本地域中的资源。

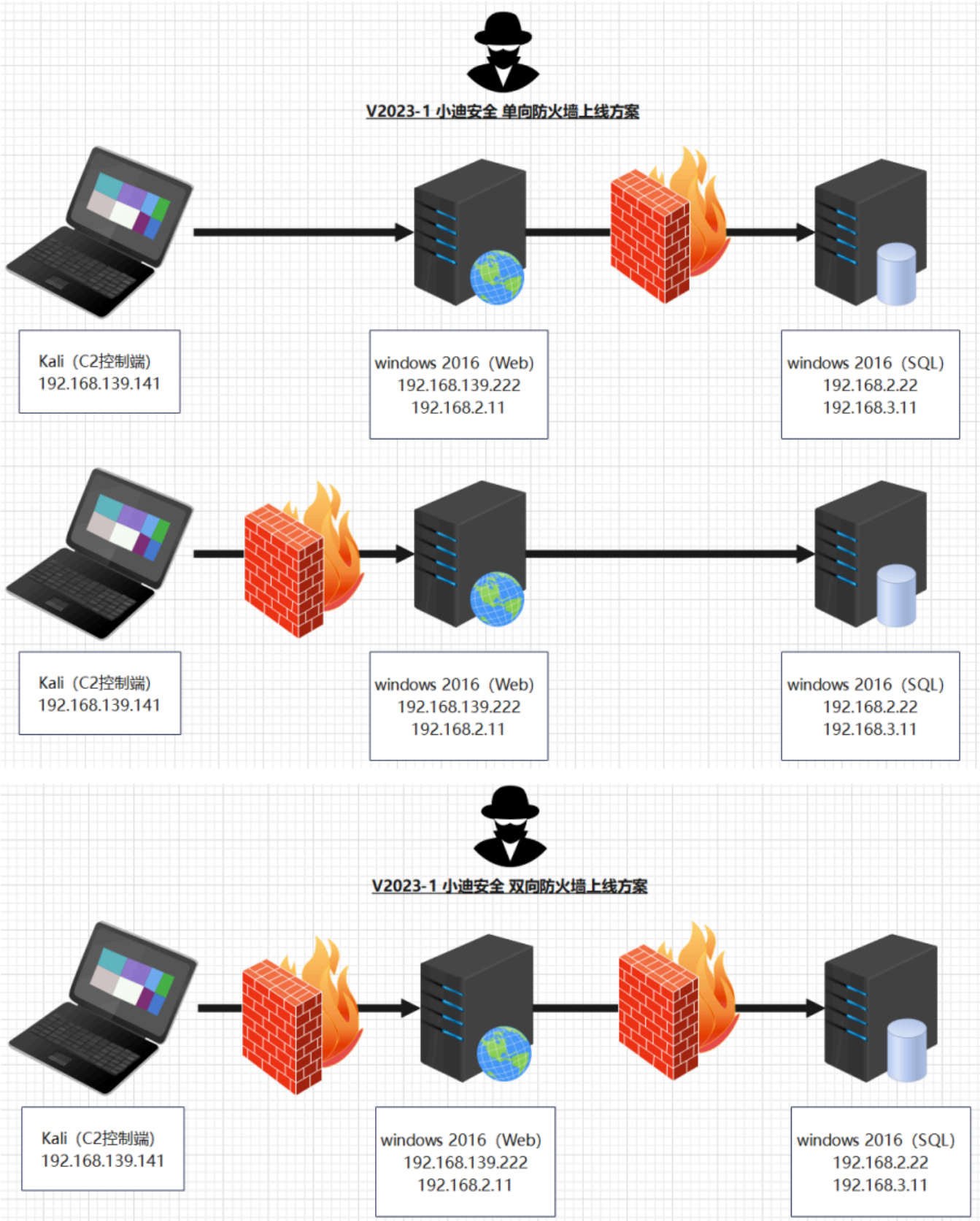
2.6 域环境应用

- 
- 1
 - 账号集中管理
 - 2
 - 软件集中管理
 - 3
 - 环境集中管理
 - 4
 - 增强统一安全性

2.7 域环境架构

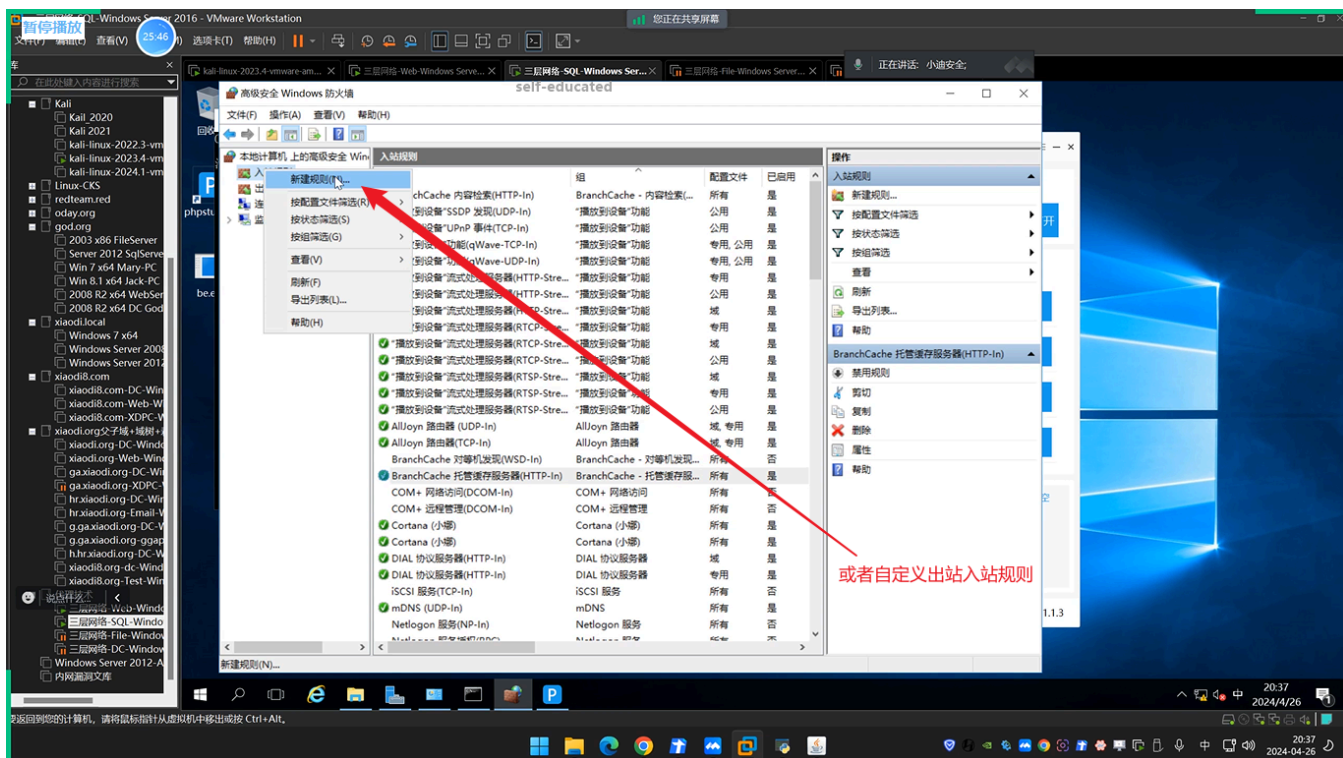
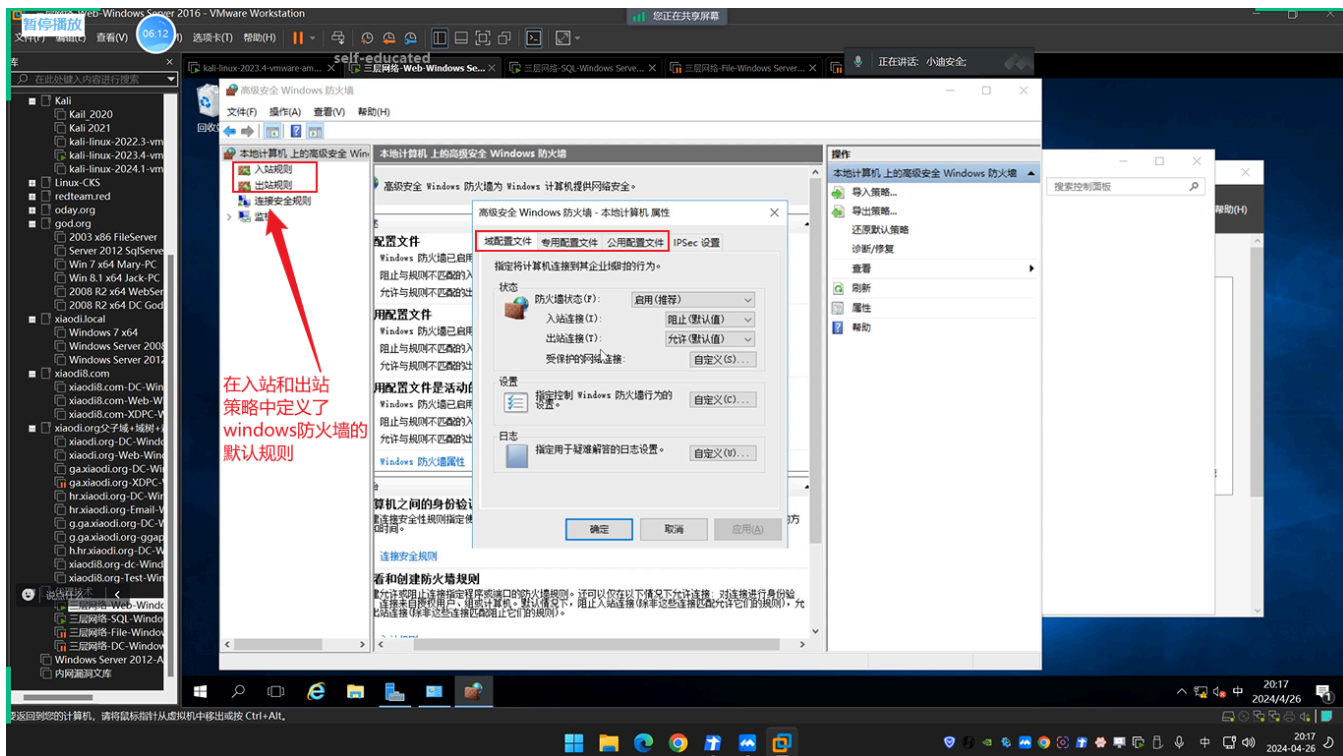
- 
- 1 域控制器
 - 2 成员服务器
 - 3 客户机
 - 4 独立服务器
 - 5 见图：（单域，父域，子域，域树，域森林）
 - 6 单域是指网络环境中只有一个域，建立一个单独的域足以。
 - 7 父子域在一个域中划分出多个域，被划分的域为父域，划分出来的域为子域。
 - 8 域树中的命名空间具有连续性，并且域名层次越深，级别越低。
 - 9 域林是指一个或多个没有形成连续名字空间的域树组成的域树集合。

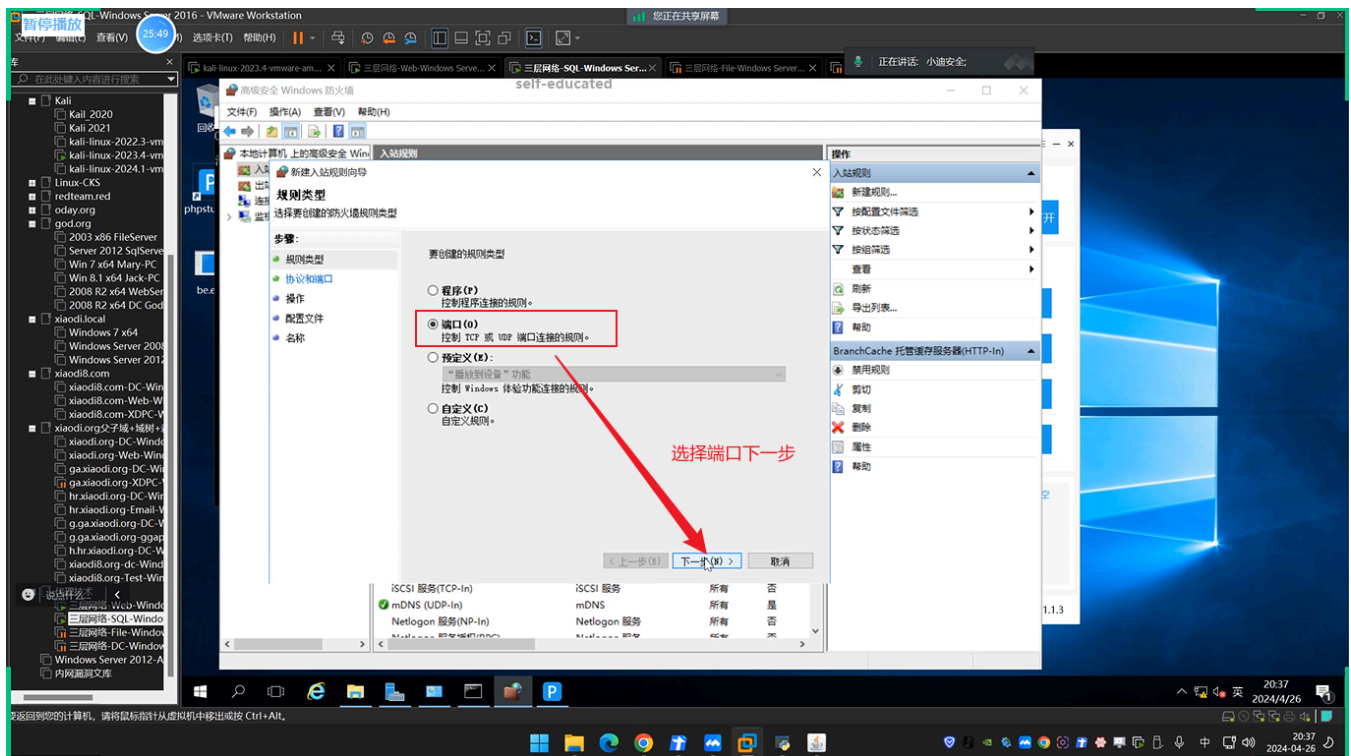
3.演示案例

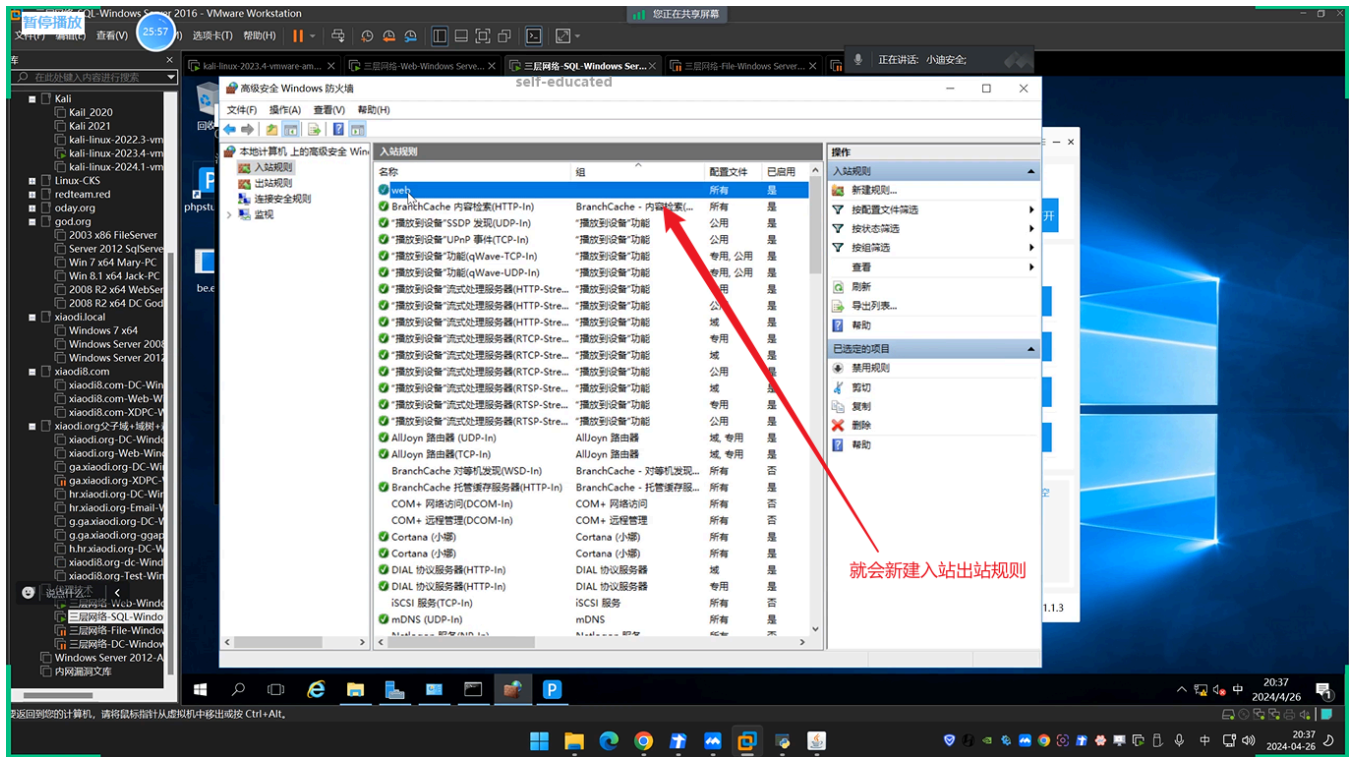


3.1 防火墙策略-入站规则&出站规则&自定义

-
- 1、防火墙默认入站&出站策略
 - 2、防火墙自定义入站&出站策略







3.2 单层防火墙-命令关闭&更改策略-C2上线

- 1 Windows防火墙命令:
- 2 参考: <https://www.cnblogs.com/tomtellyou/p/16300557.html>
- 3 查看当前防火墙状态: `netsh advfirewall show allprofiles`
- 4 关闭防火墙: `netsh advfirewall set allprofiles state off`
- 5 开启防火墙: `netsh advfirewall set allprofiles state on`
- 6 恢复初始防火墙设置: `netsh advfirewall reset`
- 7 启用桌面防火墙: `netsh advfirewall set allprofiles state on`
- 8 设置默认输入和输出策略: `netsh advfirewall set allprofiles firewallpolicy allowinbound,allowoutbound`
- 9 如果设置为拒绝使用blockinbound,blockoutbound

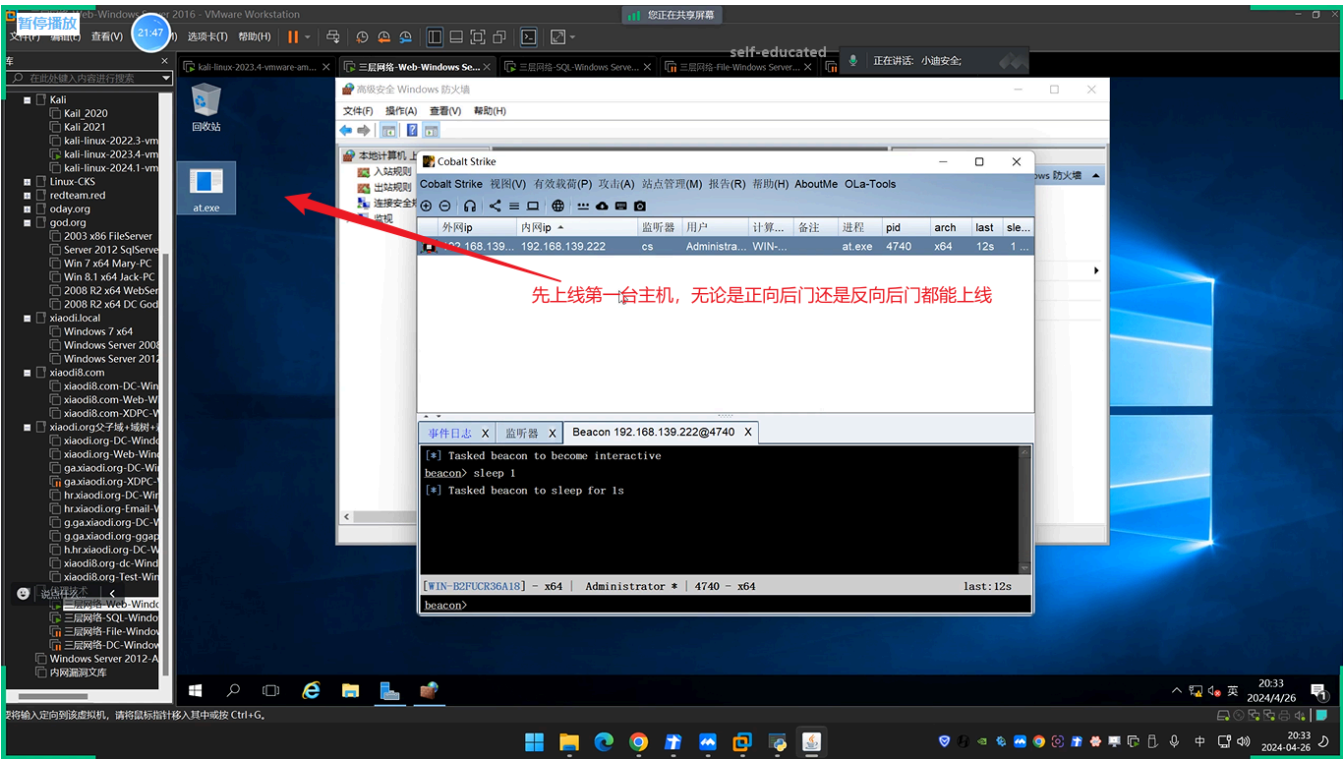
3.3 单层防火墙-正向监听&反向中转-C2上线

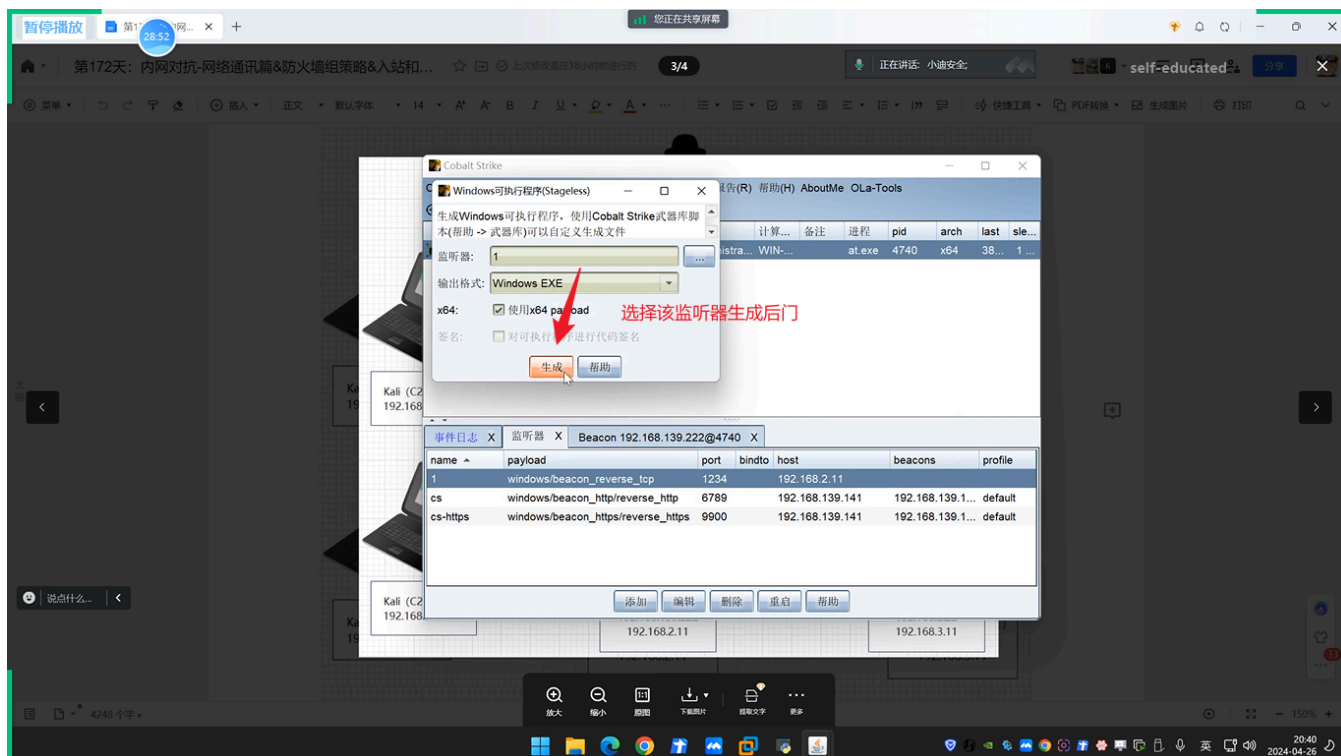
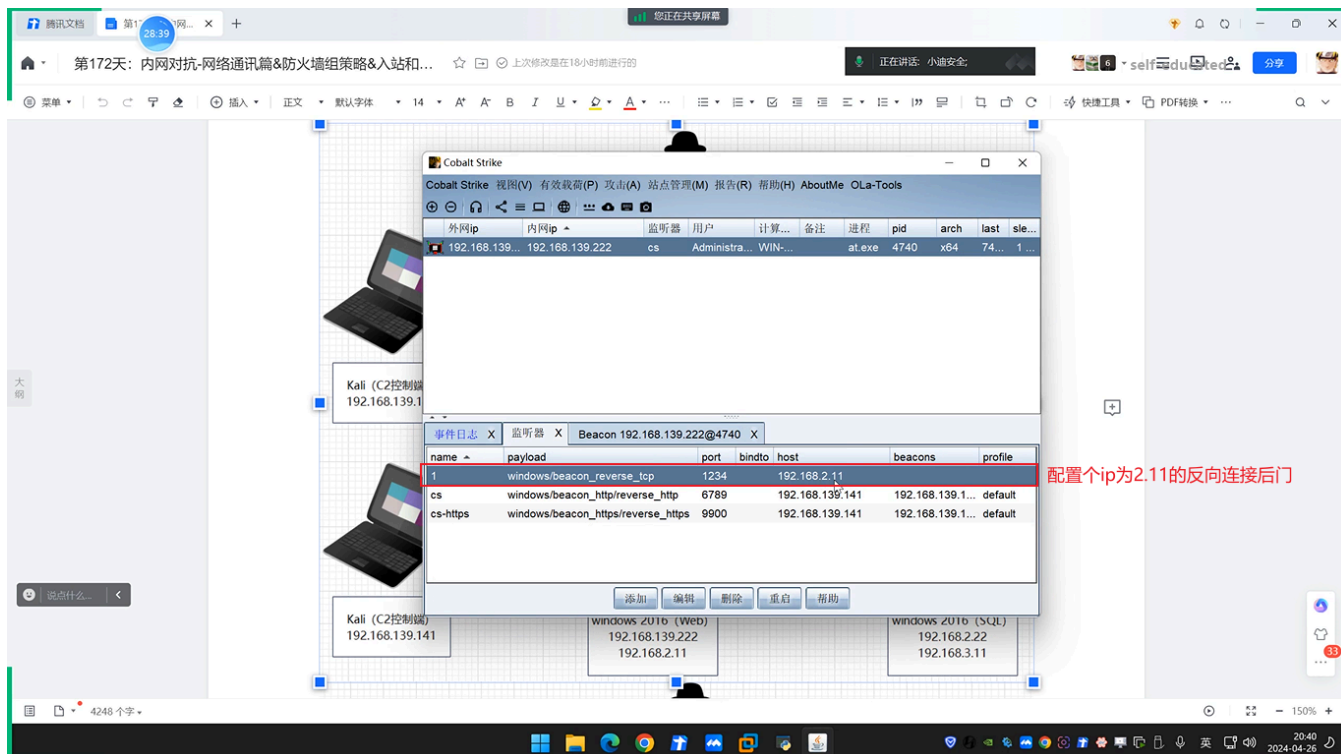
- 1 单层目标机防火墙开启上线解决方案:
- 2 1、命令关闭防火墙
- 3 2、反向中转连接上线
- 4 3、利用隧道技术上线 (规则决定)

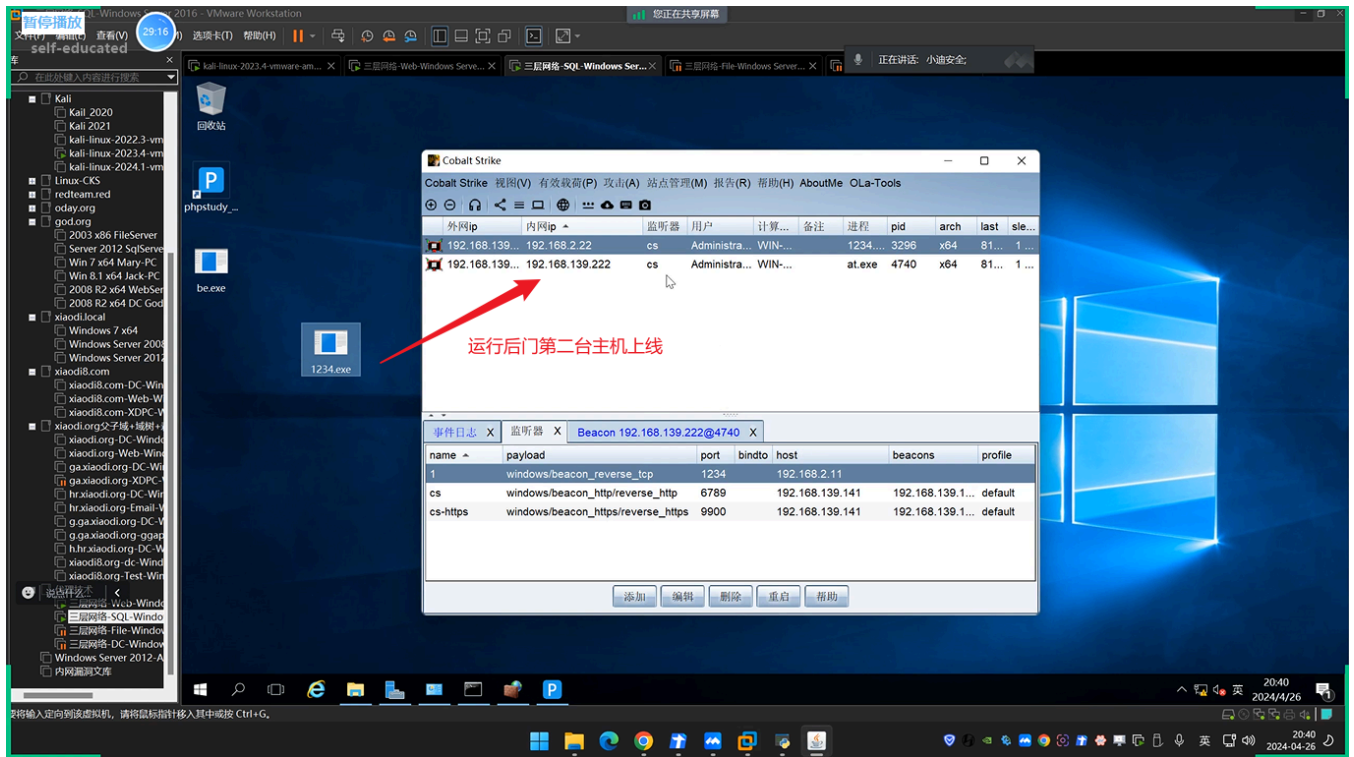
- 1 单层跳板机防火墙开启上线解决方案:
- 2 1、命令关闭防火墙
- 3 2、正向监听连接上线
- 4 3、利用隧道技术上线 (规则决定)

3.3.1 单向防火墙-第一个图

条件: Windows2016(web)关闭防火墙, Windows2016(SQL)开启防火墙

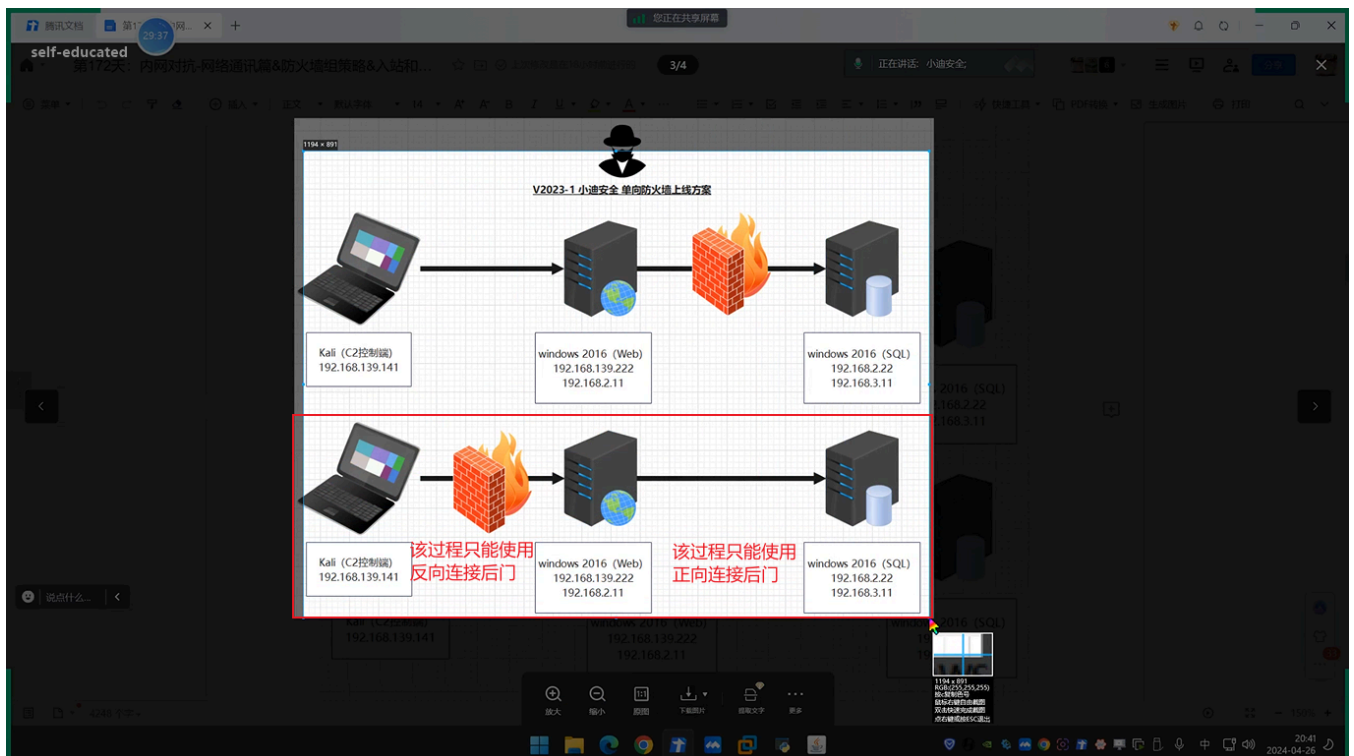


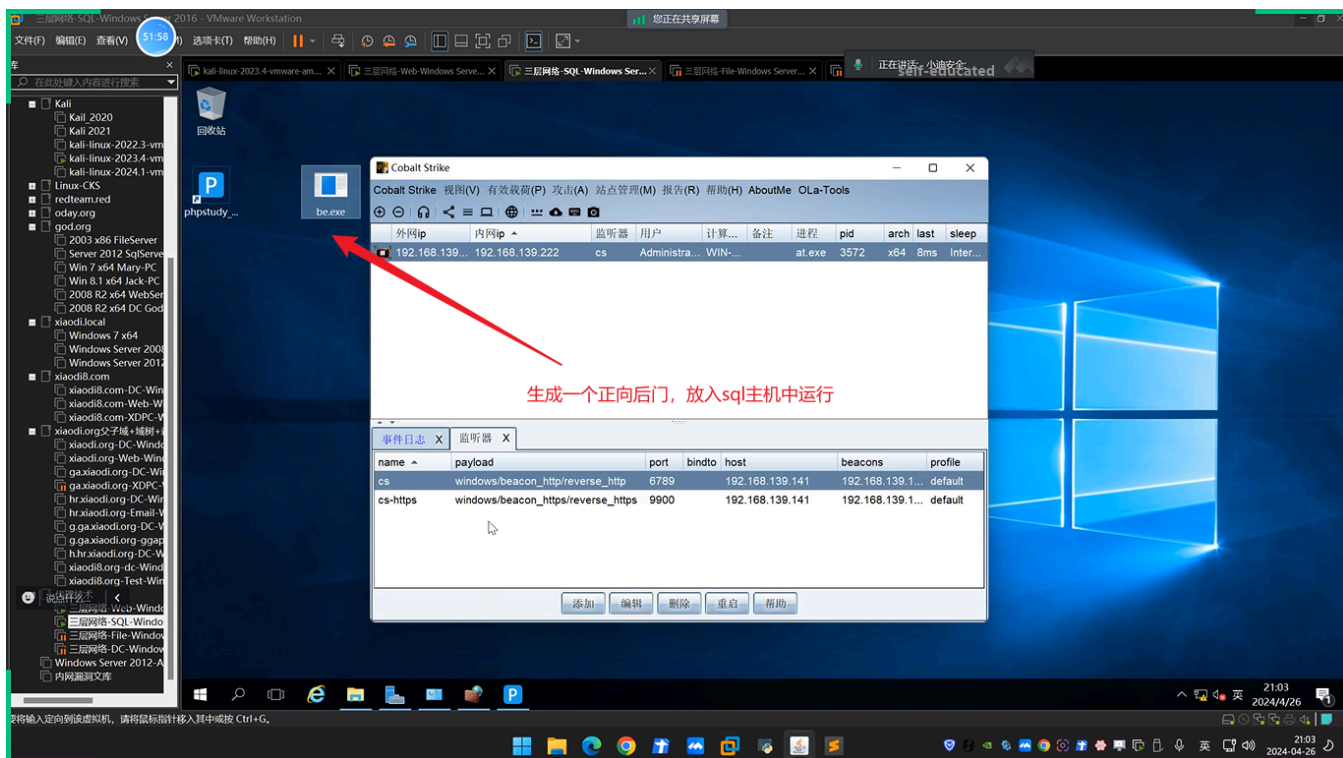
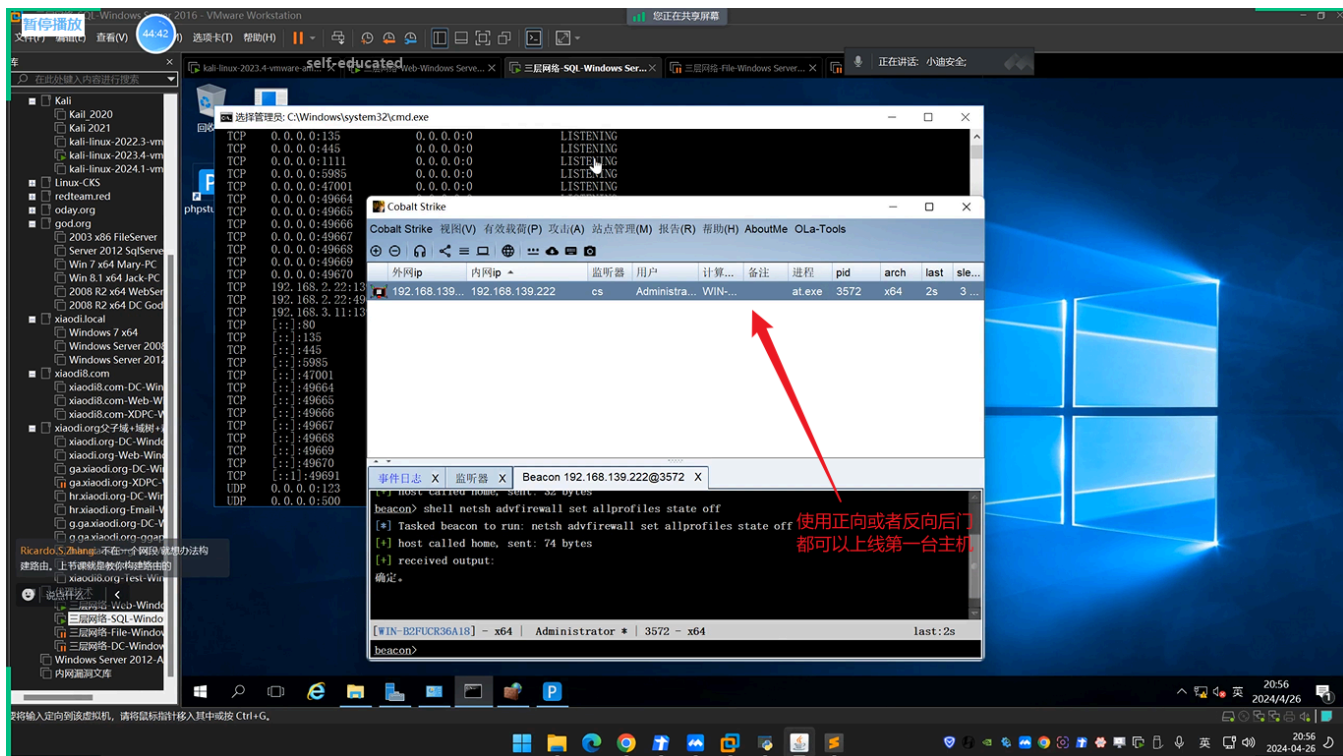


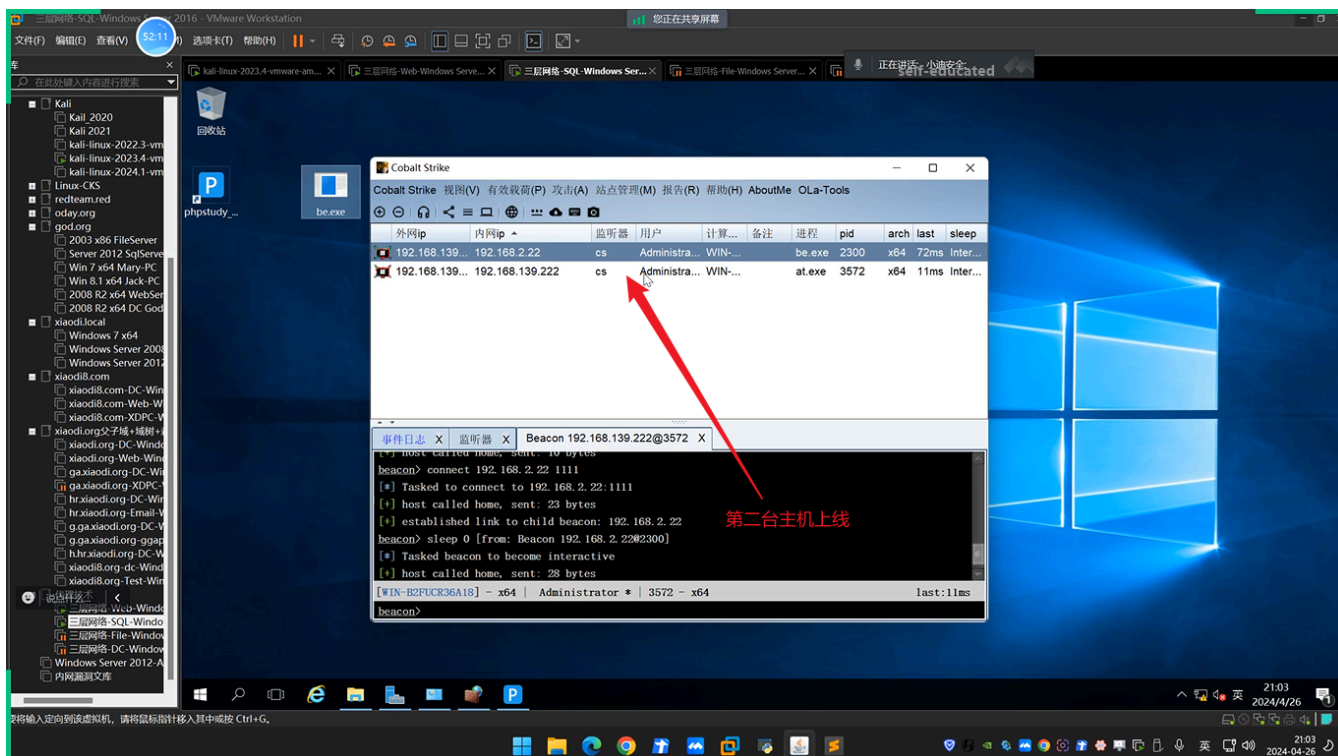
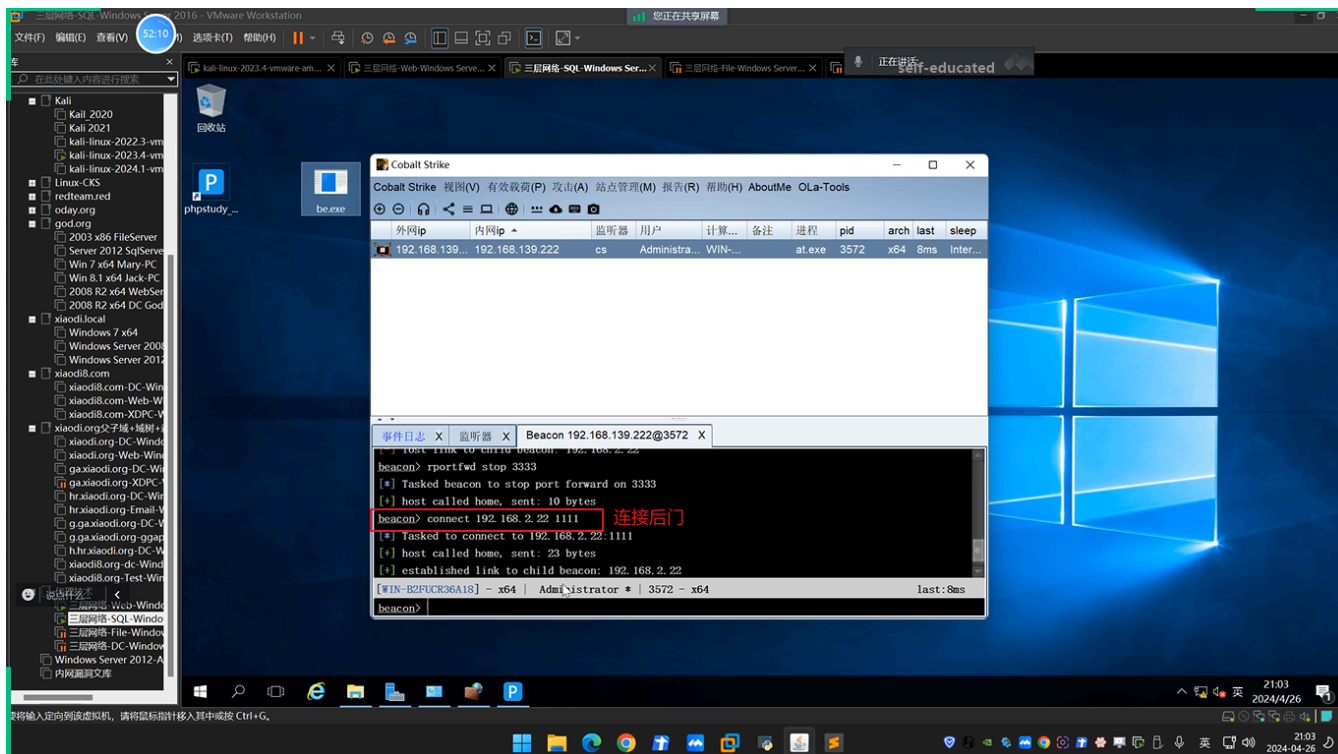


3.3.2 单向防火墙-第二个图

条件: Windows2016(web)关闭防火墙, Windows2016(SQL)开启防火墙



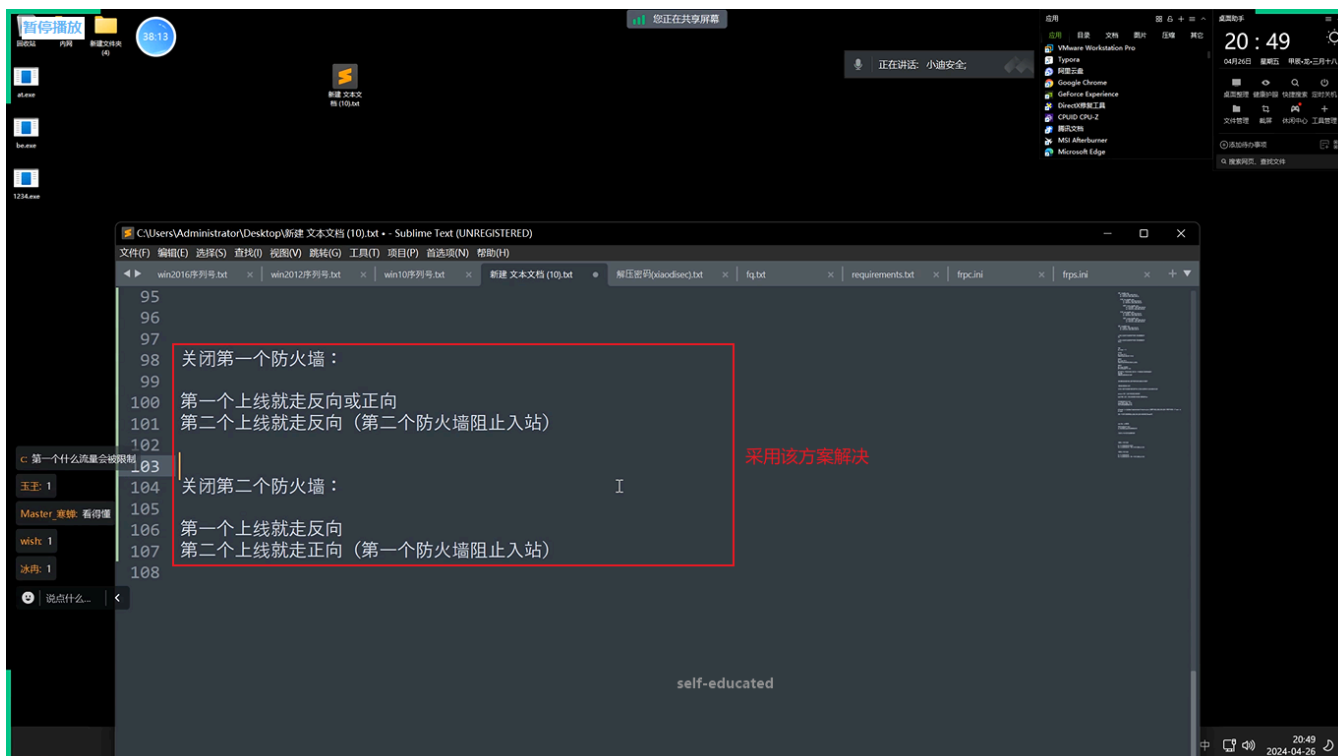
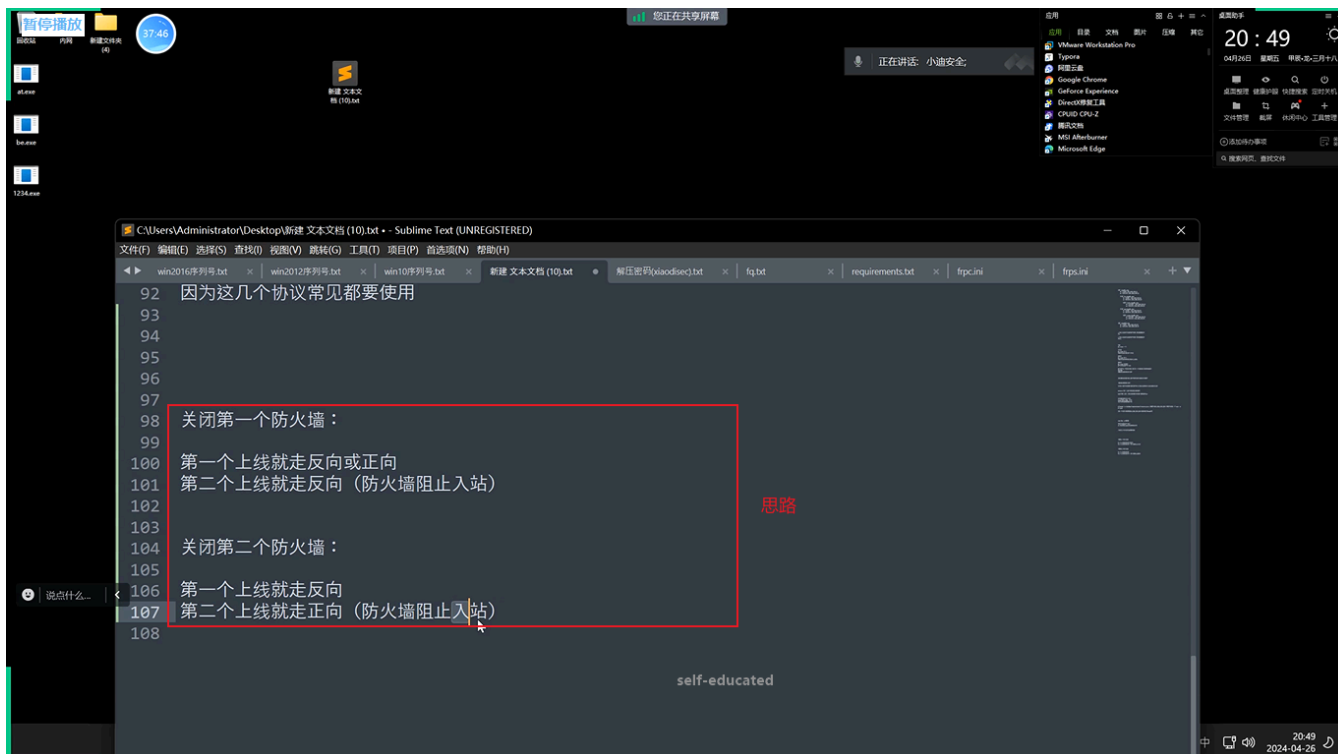




3.4 双层防火墙-命令关闭&隧道技术-C2上线



- 1 双层防火墙开启上线解决方案:
- 2 1、命令关闭防火墙
- 3 2、SMB协议通讯上线（默认放行）
- 4 3、利用隧道技术上线（规则决定）



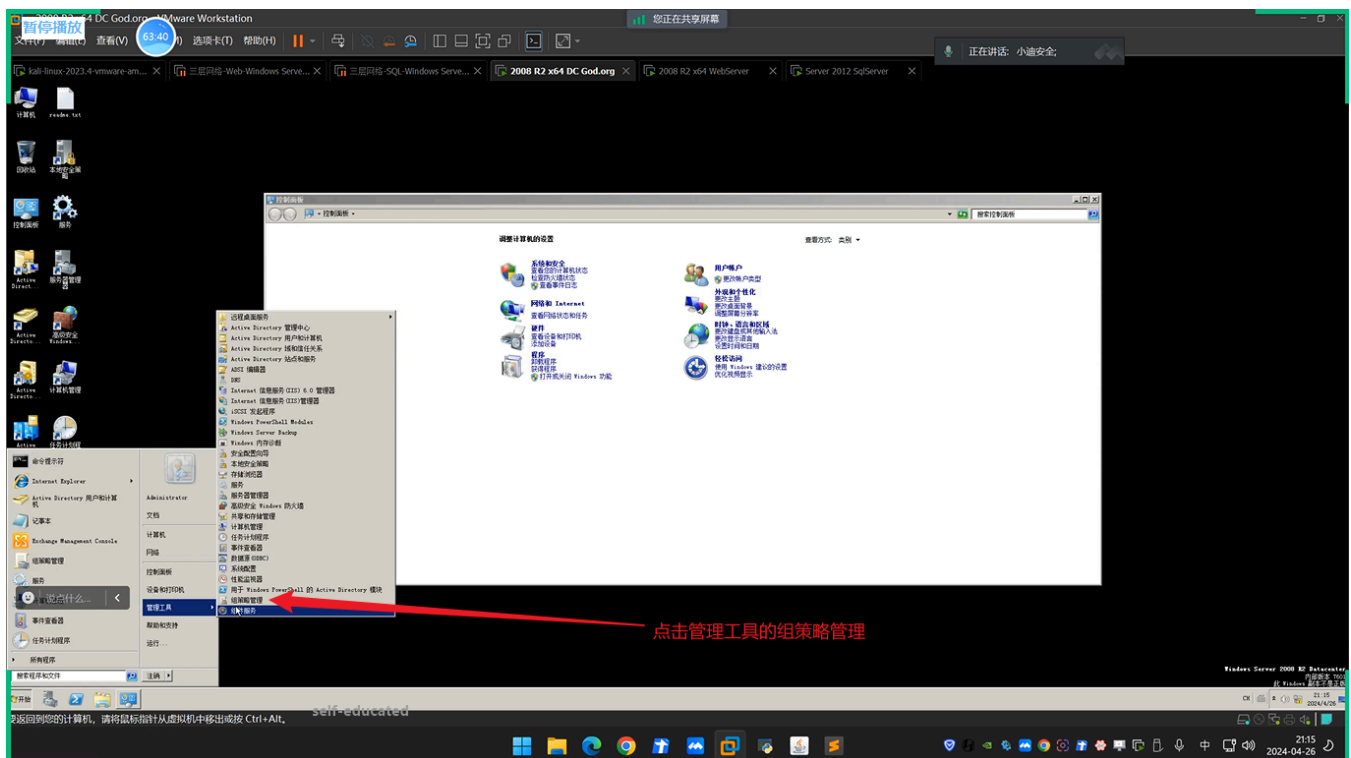
后续操作如上述单项防火墙操作

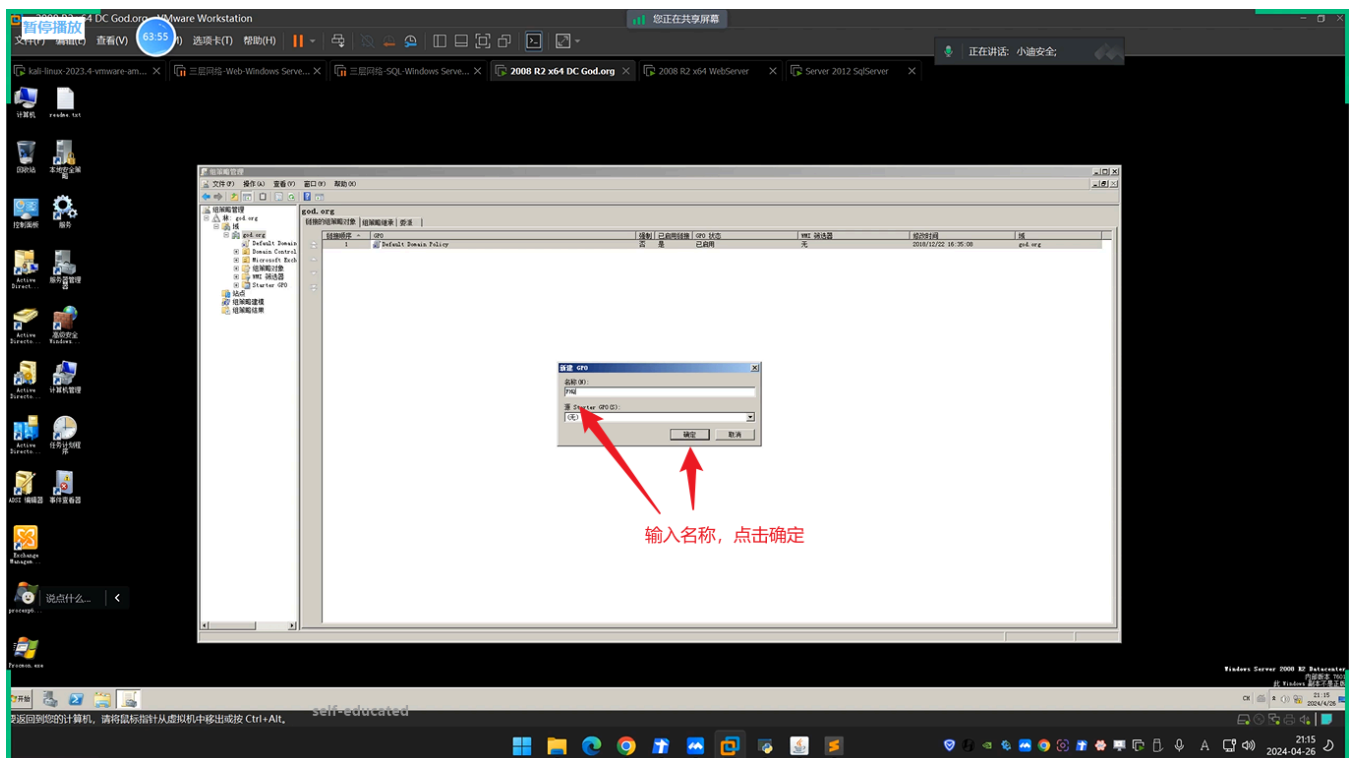
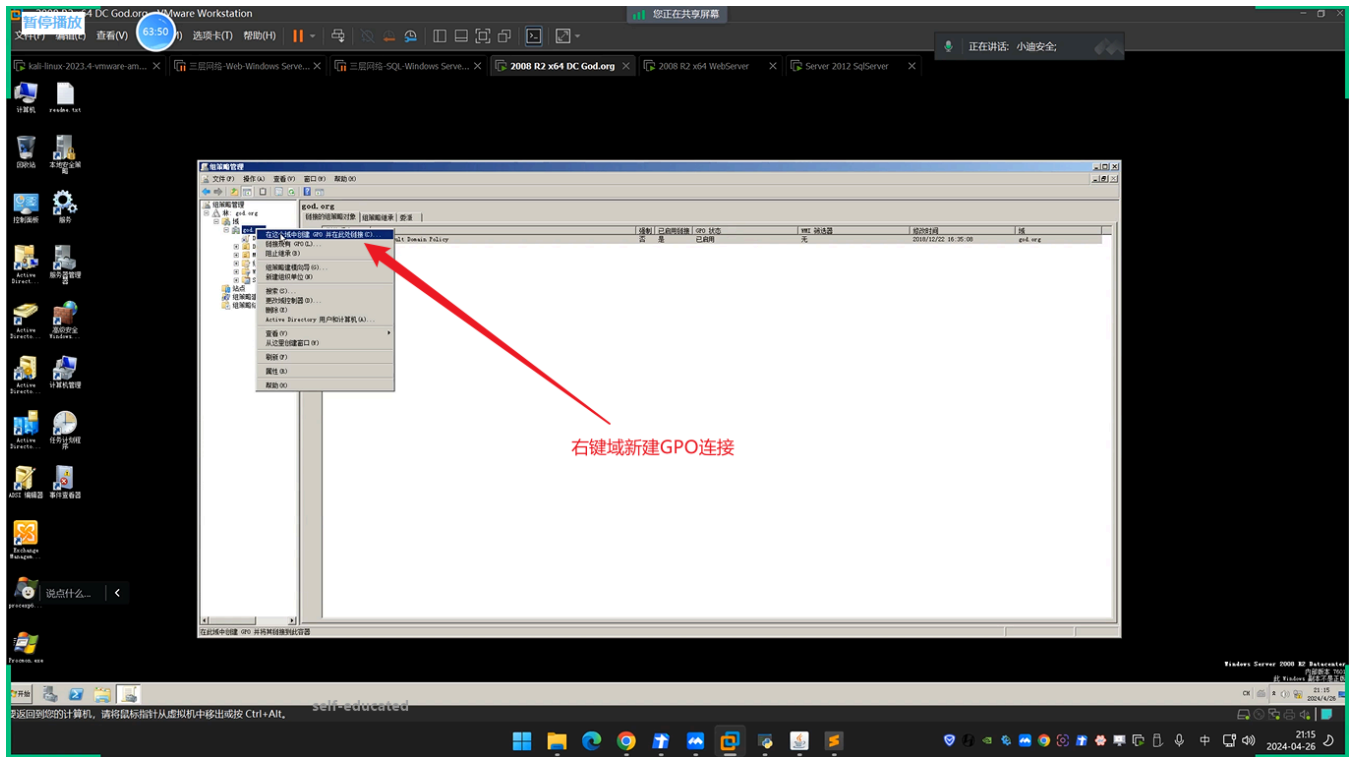
3.5 内网有域环境下（强制策略同步）

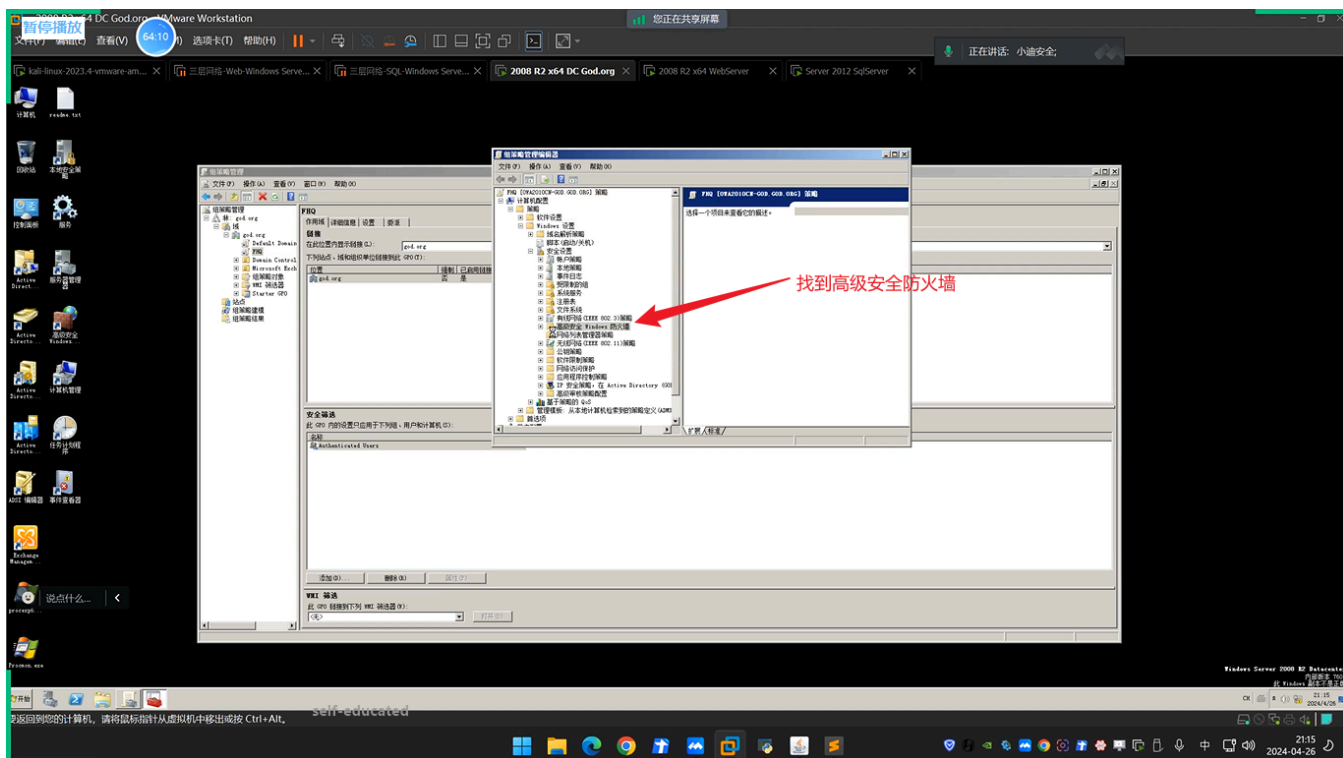
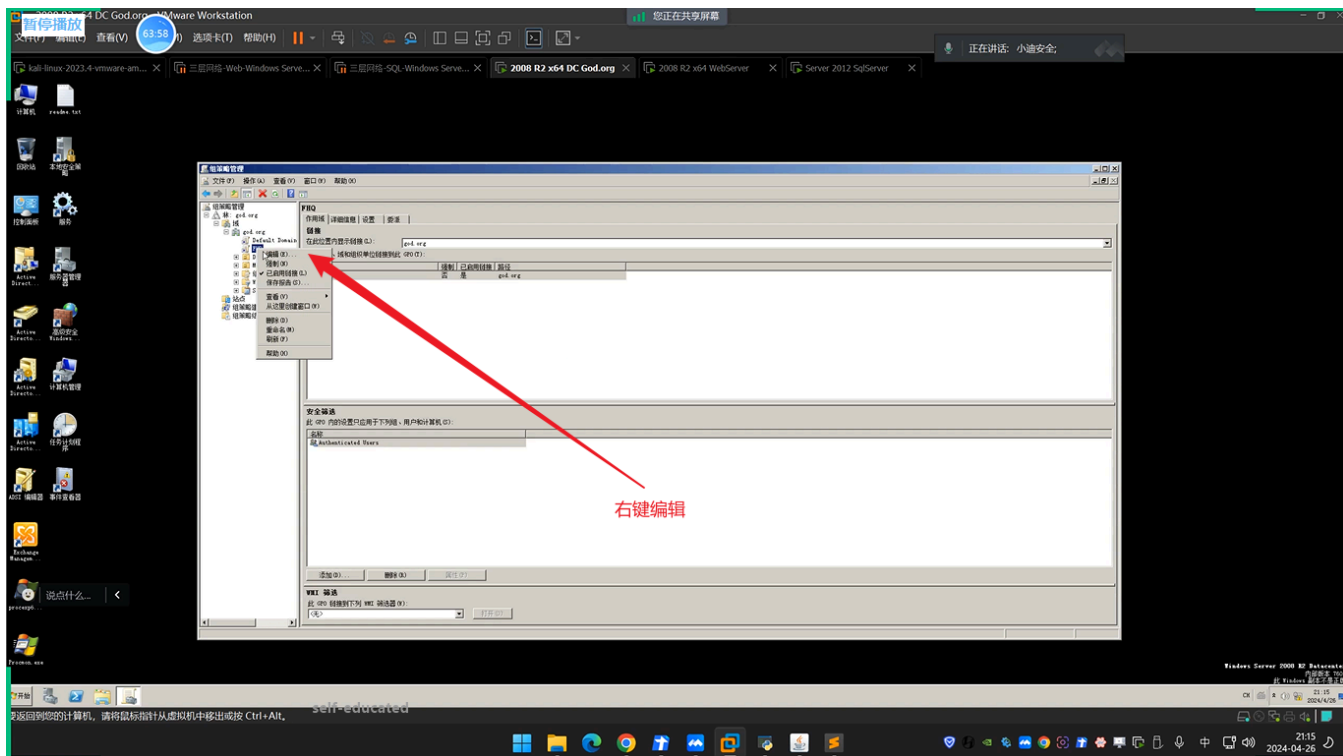
- 1 内网域防火墙同步策略：
- 2 操作：组策略管理-域-创建GPO链接-防火墙设置
- 3 更新策略：强制&命令&重启
- 4 命令：gpupdate/force
- 5

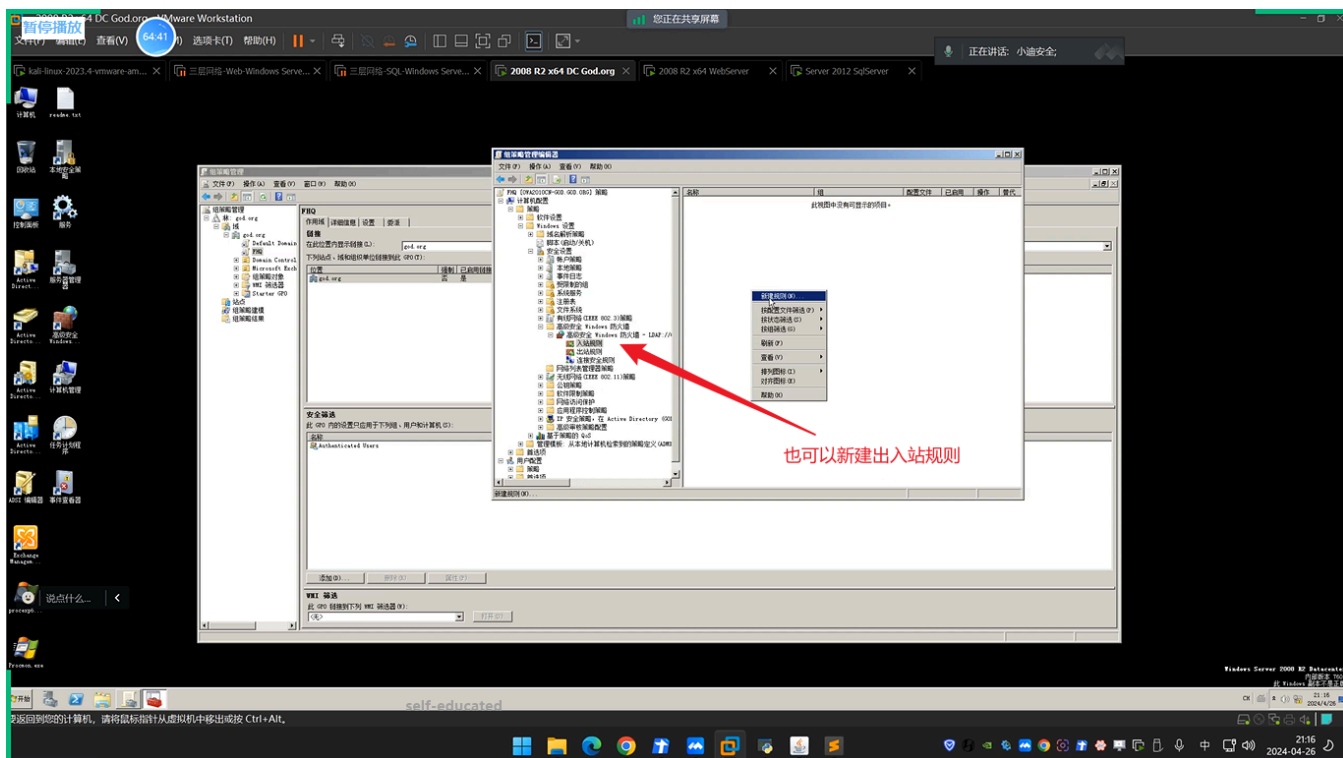
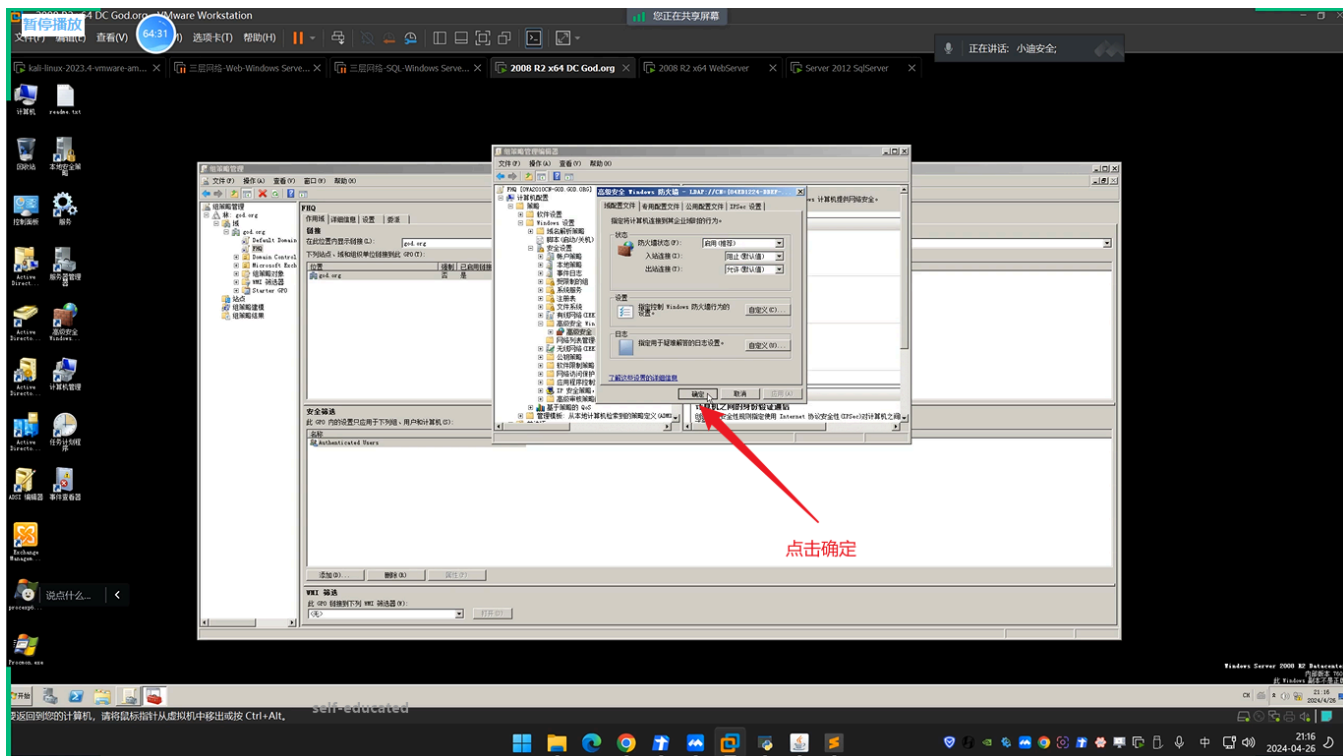
- 6 限制端口分为：入站限制端口、出站限制端口、出入站均限制端口。
- 7 入站限制端口，出站未限制端口，使用反向连接。
- 8 出站限制端口，入站未限制端口，使用正向连接。
- 9 出入站均限制端口，使用端口绕过进行连接，建议配合反向连接。
- 10
- 11 限制协议分为：
- 12 入站限制、出站限制、出入均限制，限制又分为：单协议限制、多协议限制、全部限制。
- 13 入站限制：
- 14 单协议限制，使用其它协议或者反向连接绕过。（隧道技术）
- 15 多协议限制，使用未被限制的协议或者反向连接绕过。（隧道技术）
- 16 全部协议限制，使用放弃或者反向连接绕过，但正常不会将所以协议都封闭的。
- 17 出站限制：
- 18 参考上面使用正向连接绕过。
- 19 出入均限制：
- 20 单协议限制，使用其它协议绕过。（隧道技术）
- 21 多协议限制，使用未被限制的协议绕过。（隧道技术）
- 22 全部协议限制，使用放弃绕过，但正常不会将所以协议都封闭的。

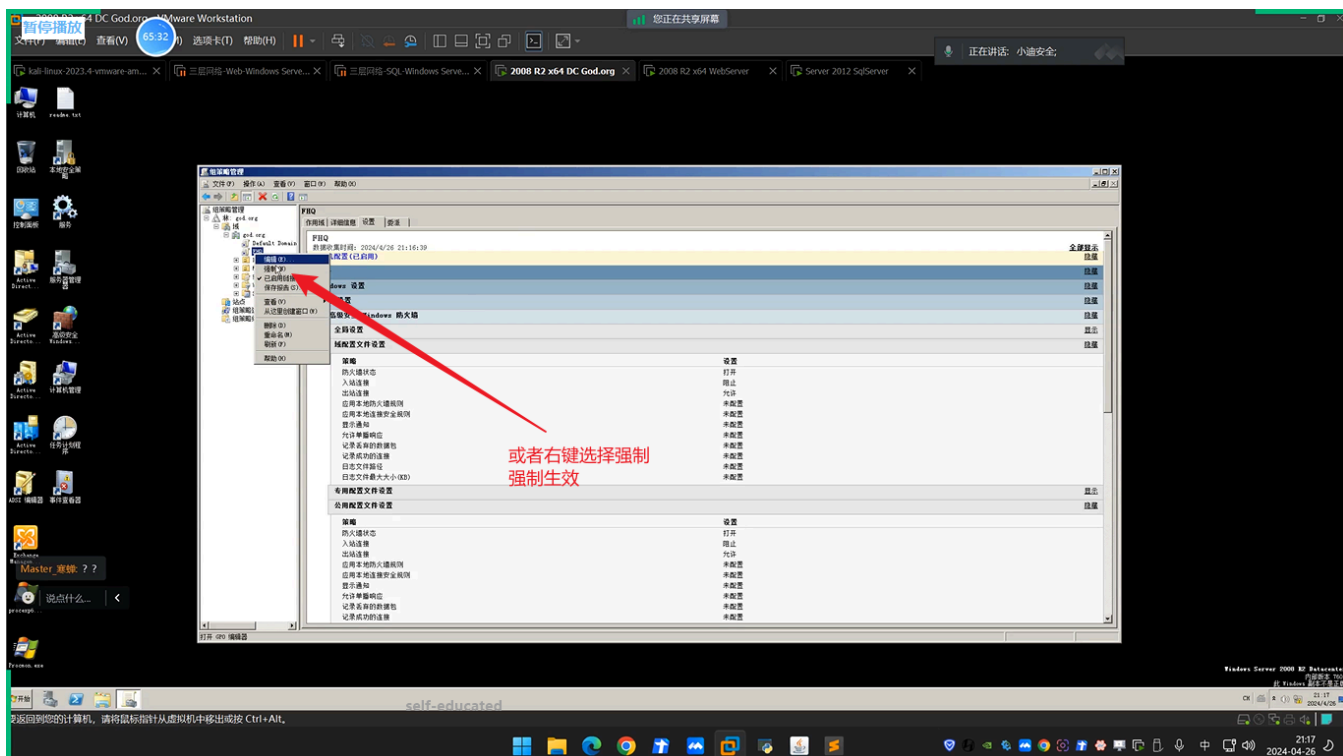
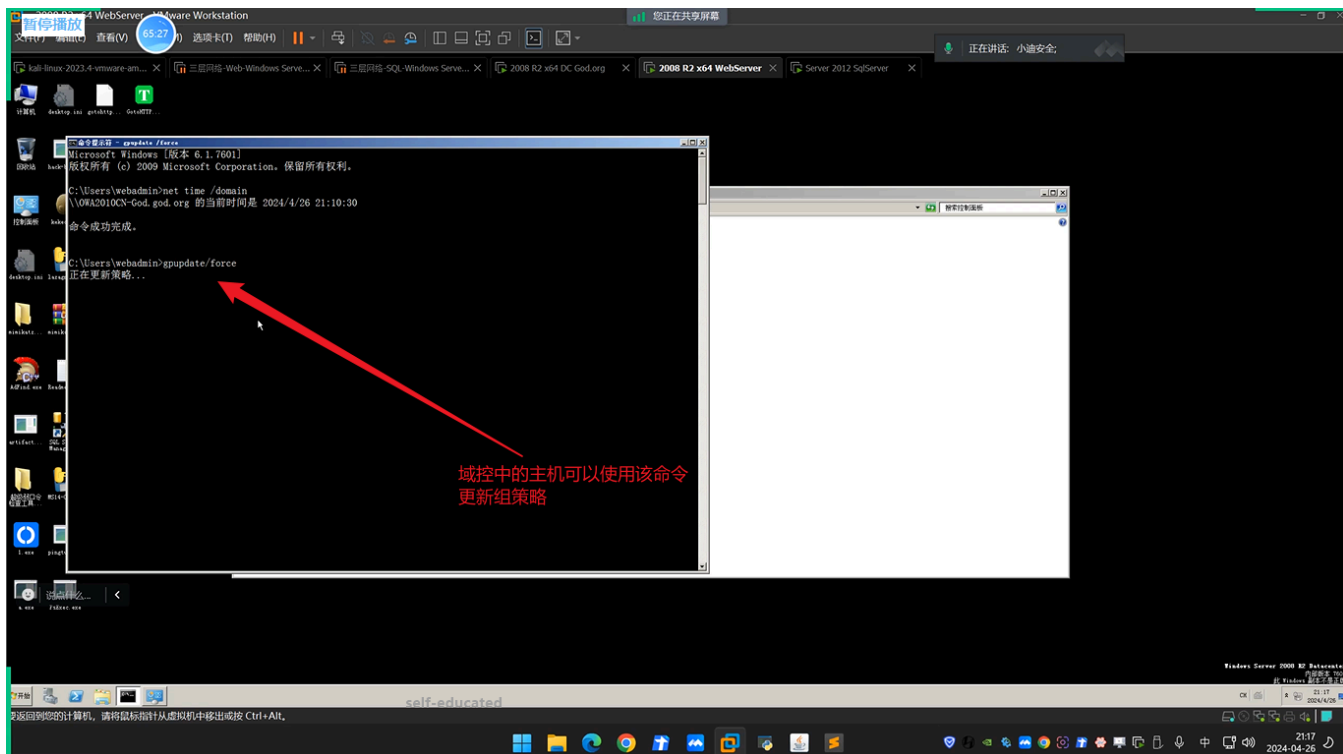
(1) 内网域防火墙同步策略：

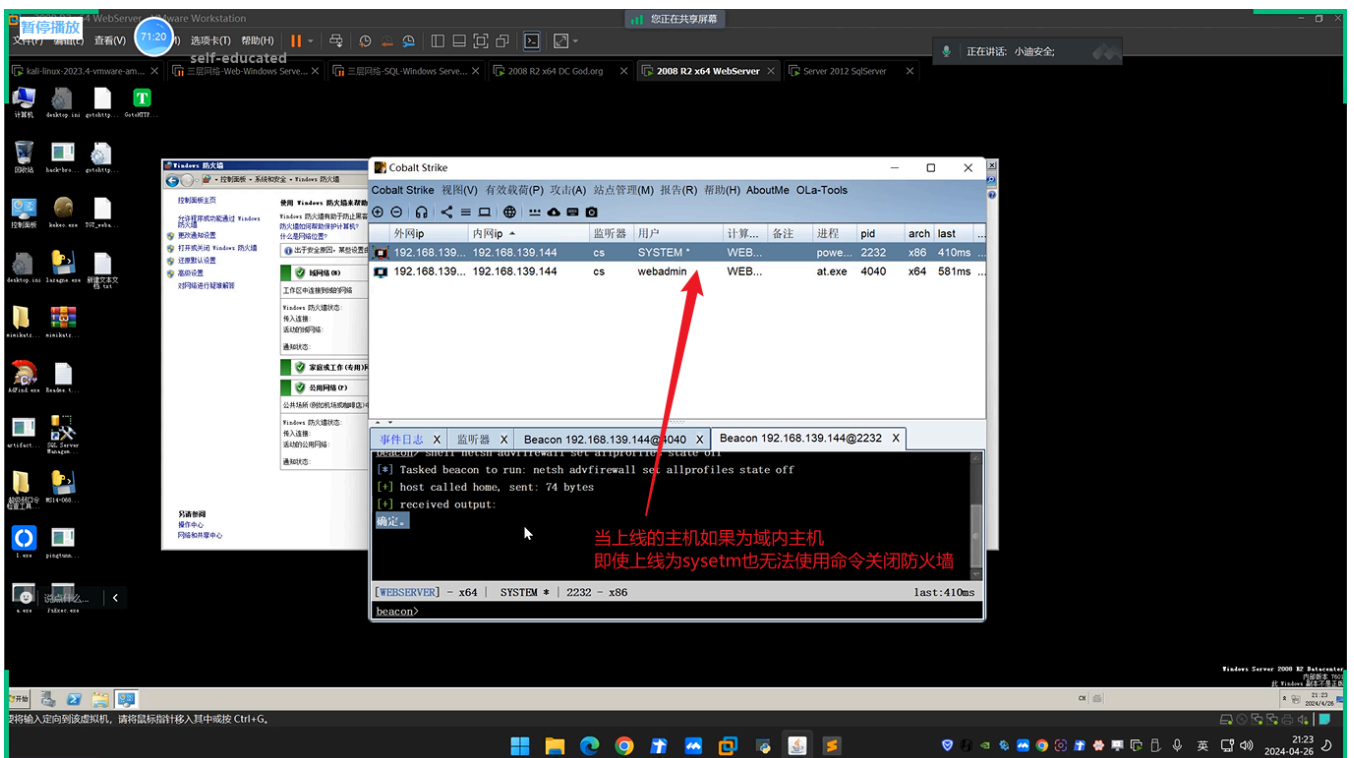
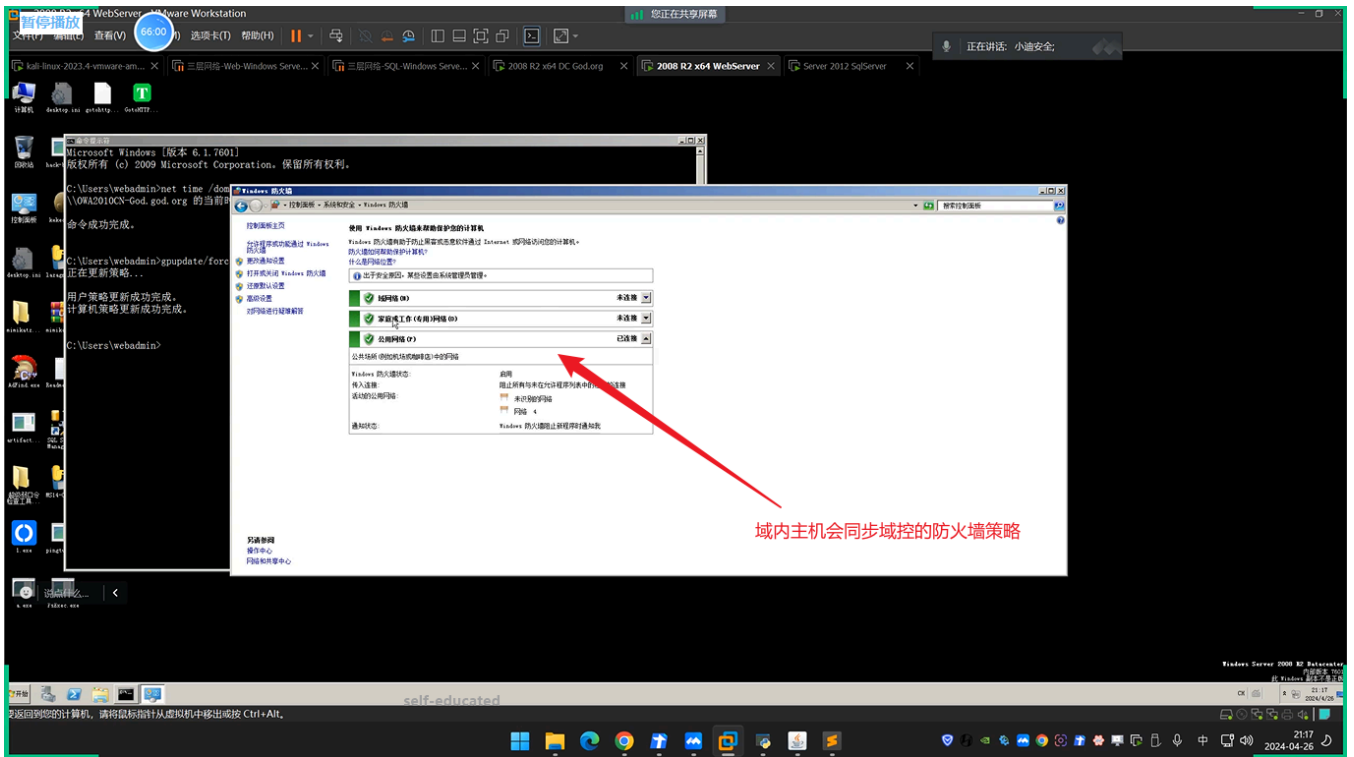












后续需要使用隧道绕过防火墙